

Security scan: findings and repairs

Captured (definition-capture) · 7 October 2026 · Production <https://definition-capture.vercel.app> · Repairs on branch `unlink-on-delete` (PR to `main`)

Scope: the whole app after the tutor conversations release. Three read-only scanners ran in parallel (Supabase: row level security, grants, functions, keys, with read-only queries on the live database; Next.js: route handlers, server pages, data access, rendering of model output; Vercel: environment variables, deployment protection, headers served), plus `npm audit` and a secret-pattern sweep of the files and the full git history. **No critical or high finding in the app itself.** The critical and high entries below are in development packages, which never run on the live site.

Findings and what was done

#	Severity	Area	Finding	Repair	Status
1	Medium	Next.js	The two server modules that read the secrets (<code>tutorServer.ts</code> : OpenRouter key and signing secret; <code>supabaseServer.ts</code> : server session) were not marked <code>server-only</code> . Nothing imported them into the browser, but a future slip would have compiled and could have bundled the signing secret.	Both now <code>import "server-only"</code> , so a browser import fails the build. The test runner maps the marker to its own empty module so the unit tests still run.	Fixed in the PR
2	Medium	Vercel	<code>TUTOR_SIGNING_SECRET</code> was also scoped to Preview (added there during the release). Preview has no OpenRouter key, so the copy served no purpose and only widened who could read it.	Preview copy removed with the Vercel CLI; Production keeps its copy (Secret type).	Fixed live
3	High	Packages	<code>npm audit</code> : <code>sharp</code> (a flaw in its SVG library) and <code>source-map-js</code> (denial of service) had fixes available.	<code>npm audit fix</code> , which needed no breaking upgrades.	Fixed in the PR
4	Critical (development only)	Packages	Vitest 3 pulled in <code>tinypool</code> (critical: prototype pollution leading to code execution) and <code>@vitest/mocker</code> (moderate: file read). Test tooling only, never on the live site. Vitest 5 had been deferred because it needs newer Node type definitions.	Vitest 3 to 5, with <code>@types/node 22</code> (the runtime is Node 24). All 844 unit tests pass on it; <code>CLAUDE.md</code> and <code>README</code> updated.	Fixed in the PR
5	Low	Next.js	A merged rule built its web-search query from the stored answers' titles, which are in the reply JSON the signature does not cover. An account could fake its own rows to steer its own search (no effect on anyone else).	The titles are now read from the first line of the signed answer text, which starts with the title. Tests updated.	Fixed in the PR

#	Severity	Area	Finding	Repair	Status
6	Low	Vercel / headers	No <code>Permissions-Policy</code> header was sent.	Added in <code>next.config.ts</code> : camera, microphone and geolocation turned off. Read-aloud (speech output) is unaffected.	Fixed in the PR
7	Low	Supabase	The old <code>conversation_messages</code> table still existed on the live database (emptied by the release; signed-in accounts still had select and delete on it).	Checked that no code reads it and that it held 0 rows, then <code>20261007195955_drop_conversation_messages.sql</code> was pushed live. Its old rehearsal file removed; docs updated.	Fixed live
8	High (development only)	Packages	<code>braces</code> 3.0.3 (denial of service through deeply nested patterns), pulled in by <code>eslint-config-next</code> through <code>micromatch</code> and <code>fast-glob</code> . Lint tooling only; the 5 remaining high entries in <code>npm audit</code> are this one chain.	None possible: 3.0.3 is the newest release of <code>braces</code> . Recorded; revisit when a patched version exists.	Open, no fix exists
9	Low	Next.js	The tutor route handlers do not check the request's <code>Origin</code> ; protection against cross-site posts rests on the session cookie being <code>SameSite=Lax</code> .	Not changed: <code>SameSite=Lax</code> is the accepted protection here. Can be made explicit later.	Accepted
10	Low	Next.js	The proxy's exclusion pattern for crawler files has no end anchor, so paths starting with those names skip the proxy.	Not changed: every workspace page and route checks the session again, so nothing is exposed.	Accepted
11	Low	Next.js / Vercel	The content security policy keeps <code>script-src 'unsafe-inline'</code> .	Not changed: documented in <code>next.config.ts</code> (the sign-in pages are static, so no per-request nonce). Nothing in the app injects markup.	Accepted
12	Low	Supabase	An account can call <code>search_tutor</code> directly, skipping the 100-an-hour count; it can link a rule to its own answer in another conversation; <code>updated_at</code> is writable by the owner; the row limits can be passed by one or two when inserts race.	Not changed: each affects only the account's own data and spends no model money (the embedding is supplied by the caller; results capped at 50).	Accepted

Checked and found sound

Account isolation	Row level security on every table, live; no <code>security_definer</code> function; every function has a fixed empty <code>search_path</code> ; composite keys make links between two accounts' rows impossible; signed-out visitors (anon) have no table or function access.
Server routes	Every tutor route re-checks the session with <code>getClaims</code> and trusts nothing from the request (plan, usage, history come from the database); another account's conversation or answers cannot be reached; all refusals come before a message is spent.
Made-up answers	Only answers whose server signature verifies reach the model (history, memory, merges); the check fails closed without the secret, compares in constant time, and is bound to the account.

Injected scripts	Model and stored answers render as plain text; links are limited to http(s) and the reference sites; no <code>dangerouslySetInnerHTML</code> on any tutor path.
Secrets	No secret in any tracked file or anywhere in git history (matches were documentation placeholders only); only <code>.env.example</code> is tracked; no secret under a <code>NEXT_PUBLIC_</code> name; no service-role key anywhere.
Deployment	Preview and per-deployment URLs are behind Vercel's login; only the production domain is public. Served on production: content security policy, <code>X-Frame-Options: DENY</code> , <code>nosniff</code> , referrer policy, HSTS.
Cost abuse	Questions and merges reserve a message before calling the model; free 5 in total, paid 30 a day; search 100 an hour per account; row limits enforced by database triggers.

For the owner to check in the dashboards

- Vercel, Settings, Environment Variables: **Sensitive** is on for `OPENROUTER_API_KEY` and `TUTOR_SIGNING_SECRET`. Settings, Deployment Protection: which mode is active, and whether an automation bypass secret exists.
- Supabase, Authentication: captcha on, email confirmation, rate limits.
- Since the old table is dropped, a Vercel rollback to a deployment from before the tutor release would fail: fix problems forward.